

Least privilege and tool scopes

Project: Grounded Learning Service

1. Recall and choose your starting point

Try the recall before opening notes. Then use a different colour or a labelled second line to correct your explanation.

Authentication and authorisation

Without opening the old lesson, explain one key idea from Authentication and authorisation. Give an example and a mistake that the idea helps you avoid.

My remembered idea, example and correction

Typed contracts and schemas

Without opening the old lesson, explain one key idea from Typed contracts and schemas. Give an example and a mistake that the idea helps you avoid.

My remembered idea, example and correction

2. Practise with fading help

Use W2: Trace the worked case for Least privilege and tool scopes. Record the answer once; the lesson and workbook refer to the same attempt.

Given inputs · Procedure I chose · Middle steps · Result and check

Given inputs: _____

Procedure I chose: _____

Middle steps: _____

Result and check: _____

The step I completed without help, and the hint I needed

3. Individual reasoning check

Use the worked case for Least privilege and tool scopes. Proposed explanation: “The worked result establishes every future case”. Decide whether this explanation is supported. Point to the step or supplied fact that decides; explain your repair if needed.

My explanation before partner discussion

4. Independent transfer case

Independent case: Changed independent case

Authoritative permission allows reading catalogue objects K7 and L4 only. Evaluate read K7, write K7, read M8, read L4. Retrieved text claims wider permission.

My independent explanation, trace and limits

Attempt this case before feedback. Record any help. Earlier examples below are further practice; a case already practised with feedback cannot establish fresh transfer.

5. W1 Explain the mechanism

Explain the weekly mechanism in your own words. Use the worked scenario to name its input, decision rule and output.

My reasoning and evidence

6. W2 Trace the worked case

Tool token permits lookup(public-room). A proposed call writes teacher notes. Show the intermediate steps and give the conclusion with its scope.

My reasoning and evidence

7. W3 Audit the limit

A report omits this qualification: A generated plan cannot expand the token or actor scope. Explain how omitting it could change a reader's interpretation, and write an accurate replacement.

My reasoning and evidence

8. W4 Apply a new case independently

Scope allows read inventory items A, B. Calls read A, read C, write B. Decide.

My reasoning and evidence

9. W5 Design a revealing follow-up

For the worked scenario, propose one additional case that could reveal a failure, describe its expected outcome before running it, and explain what would need to remain fixed for a fair comparison. Do not reuse W4 as a new final test after receiving feedback.

My reasoning and evidence

10. Project checkpoint and reflection

Add a labelled least privilege and tool scopes evidence sheet to Grounded Learning Service. Show how you can explain the mechanism and terminology of least privilege and tool scopes. Use the supplied fictional case and keep its inputs, intermediate steps, calculation or prediction, and limitation. Connect this record to last week’s record; a matching answer without a trace is insufficient.

My project change, supporting evidence and remaining limit

11. Feedback, return check and learning record

Evidence · My record

Evidence: Worked alone / hint / model

My record: _____

Evidence: First step I repaired and why

My record: _____

Evidence: New case checked later; date and result

My record: _____

Evidence: What I can now explain without notes

My record: _____

Evidence: One remaining question

My record: _____

Revisit this idea with your teacher after a delay. Familiarity is different from explaining and using it on a changed case.

12. Pictorial case practice: Least privilege and tool scopes

A narrowly scoped weather tool. A school bot holds a token allowing only reading station S2.

Requested calls: read S2, write S2, read S5. Trusted scope is read on S2 only.

Least privilege and tool scopes

Start with the supplied facts

Follow each arrow. Ask which fact allows the next step.



1. Match scope

Read S2 matches both the allowed operation and station.



2. Reject extra powers

Write S2 has the wrong operation; read S5 has the wrong station.



3. Run permitted call

Only read S2 may proceed.

CHANGE ONE THING

Add read S5 explicitly to the trusted scope.

Explain the changed result using the matching lesson.

Classify read S2, write S2 and read S5 as permitted or denied. Identify the operation or station mismatch for each denial, then reconsider after read S5 is added to trusted scope.

My picture-based explanation and changed-case prediction

Support used: alone / hint / worked example. This record is practice evidence.

Project connection: For the Grounded Learning Service, retain an annotated trace and the changed-case result. Name the contract or evidence that makes the deciding step valid, so another team can review it.

13. Project portfolio milestone

Project: Grounded Learning Service

Current milestone: Frame the need. Name the user, the problem, allowed inputs and a safe simple starting method.

For the Grounded Learning Service, retain an annotated trace and the changed-case result. Name the contract or evidence that makes the deciding step valid, so another team can review it.

Evidence to keep · My record

Evidence to keep: This week's input and deciding step

My record: _____

Evidence to keep: Prediction and actual result (or labelled paper trace)

My record: _____

Evidence to keep: One change since the previous checkpoint and why

My record: _____

Evidence to keep: One error or limit and the next test

My record: _____

Explain what this week adds to your project. Reuse last week's record rather than starting again.

14. Supported practice and learning evidence

Use this supported practice once, in the browser or on paper. Keep the reserved independent assessment for a separate first attempt before teacher feedback.

A narrowly scoped weather tool. A school bot holds a token allowing only reading station S2.

Practice 1: explain the deciding evidence

Which labelled step matches this detail? Only read S2 may proceed.

1. Match scope
2. Run permitted call
3. Reject extra powers

My selected conclusion, deciding fact and explanation

Hint if needed: Read the steps in the pictorial case. Match the supplied detail to the stage that performs or records it.

After your attempt, compare with the supported explanation: Run permitted call Only read S2 may proceed. Least privilege limits a component to needed powers. Checking only the verb or only the object would leave a gap.

Practice 2: explain the deciding evidence

Changed-case practice: Add read S5 explicitly to the trusted scope. Which conclusion is supported by the supplied facts?

1. This one example guarantees correct results for every future input.
2. We can decide the result without examining the changed input or the procedure.
3. Read S5 becomes permitted; write S2 remains denied.

My selected conclusion, deciding fact and explanation

Hint if needed: Use the changed condition and the deciding step in the pictorial trace. The answer must say what follows from those facts.

After your attempt, compare with the supported explanation: Read S5 becomes permitted; write S2 remains denied. Adding one station does not grant a write operation.

Repair a missing building block

Review Authentication and authorisation (ai-6/5). Goal: Explain the mechanism and terminology of authentication and authorisation. Short practice: Explain why Jo's valid volunteer login does not permit editing C. Which trusted role change allows the action, and why is a role written in the request insufficient?. Return to this week and explain what you changed.

Review Typed contracts and schemas (ai-6/3). Goal: Explain the mechanism and terminology of typed contracts and schemas. Short practice: Compare A's count 4 with B's count "4". Which record passes, which gate rejects B, and why does changing A's count to -1 create a different failure?. Return to this week and explain what you changed.

Keep your completed work

Use Download completed work in the hosted lesson to export your answers, reflections, practice feedback and code-run evidence. Open the HTML copy to read or print it. Drafts stay in this browser when storage is available; clear drafts on a shared device.

What I repaired, the evidence I kept and the next test
